Connect Group — Astro Fleet Change Report

Prepared for Aaron (owner / host) • 11 Aug 2026 • branch **work/astro-sites** • 34 keep sites

Summary

Four fleet work items were completed **in git and verified locally**. Nothing was deployed and no live system was touched — the 28 live sites still run the current immutable release until you rebuild and ship a new one. The headline change: **website contact forms now detect the visitor's country from Cloudflare** (`Cf-Ipcountry`) instead of the browser calling the third-party `ipinfo.io` service — which was the cause of the wrong dial-code bug. This is applied to **all 34 sites**.

What changed — at a glance

Item	Change	Status	Needs you (owner)
FQ-02 Geo / dial-code	Forms read country from Cloudflare `Cf-Ipcountry`; all browser calls to ipinfo/ipwho/geojs/ipapi removed; always defaults to **AE**.	Done in git — **34/34**	Linux rebuild + new immutable release
FQ-01 nanoid security	Dependency `nanoid` 3.3.16 → 3.3.18 (DoS advisory RA-01), pinned once at workspace root.	Done in git; 2 builds pass	Same Linux rebuild + release
FQ-00 Script veto	Marked the staged `APPLY.sh` / `APPLY-NEXT6.sh` as DO-NOT-RUN in every doc, per your findings.	Docs updated	Rewrite scripts (safe shape below)
FQ-03 Memory	Recommendation written: keep **per-site** memory caps, raise heavy mirrors first. No live change.	Note written	Apply memory bump on host
FQ-04 Source review	Already closed; spot-checked. Fixed one stale peer domain in MBS SEO output.	Verified	None

FQ-02 — Cloudflare country detection (the form fix)

The bug: the contact forms called `https://ipinfo.io/json` from the visitor's browser to guess their country and set the phone dial code. Free-tier limit is ~50k requests/month but the fleet was making **880,146** calls. When the call was rate-limited or timed out, **no default country was set** — the visitor typed a bare number and got the wrong dial code. Intermittent, looked random.

The fix: Cloudflare already tags **99.92%** of requests with `Cf-Ipcountry`. Each site now reads that header server-side and hands the country to the form widget; the browser makes no third-party call at all. If there is no usable header (local/dev, `XX` unknown, `T1` Tor) it falls back to **AE** — the widget is **always** initialised. Bonus: no visitor IPs sent to ipinfo (GDPR), no third-party round-trip.

Coverage & verification

Check	Result
Sites reading Cloudflare `Cf-Ipcountry` (server)	**34 / 34**
Sites with zero third-party geo in form scripts (client)	**34 / 34**
Live test — no header	→ `ae` (fallback) ✓
Live test — `Cf-Ipcountry: SA`	→ `sa` (from Cloudflare) ✓
Live test — `XX` / `T1`	→ `ae` (fallback) ✓

Not rewritten (by design): ~**3,357** legacy WordPress-export / vendor files across the fleet still contain the old inline ipinfo snippet. These live inside the hash-pinned immutable release, which cannot be edited in place. Our maintained form script overrides them at runtime, so the bug is fixed regardless; they will be replaced when you build the next release.

FQ-00 — Staged scripts: safe replacement shape

Both scripts are now marked **DO-NOT-RUN** in the docs. Suggested safe rewrite (for you to implement on the host):

• **Signatures** — copy the PNGs into a **new** immutable release (or a dedicated signed artifact). Never patch the attested release tree from the user-writable `staging/` directory.

• **Next-6 enable** — transactional enable with a health-check **abort** (fail closed), **no** in-tree `astro build` on the live unit, and **no** `sed` of `site-ctl` (generate the allowlist instead of text-substituting it).

FQ-03 — Memory (recommendation, no live change)

• Keep **per-site** memory caps — a shared pool lets one heavy site (Connect Resources) starve the whole fleet.

• Connect Resources is dying because its unit cap is `MemoryHigh=200M/Max=256M` (`MemoryAvailable=0`) — not because the ~15 Gi host is full.

• Raise heavy WP mirrors first: `MemoryHigh=384M / MemoryMax=512M`; keep thin leads sites at 256M. Even better: serve `/wp-content/, /css/, /js/` via Caddy `file_server` so Node is not the static CDN. A restart alone will not stick.

What we need from you (owner)

1. **Rebuild all 34 on Linux** and cut a **new immutable release** — this is what actually ships the geo fix + nanoid bump to visitors (app-only rsync will not; live 28 run the pinned release).
2. **Rewrite** the two staged scripts per the safe shape above before any next-6 cutover.
3. **Apply the memory bump** on heavy mirrors (Connect Resources first).
4. After deploy, spot-check a form: with a real visitor the dial code should match their country; from a VPN it should follow the exit country; local always shows AE.

Scope of the change set: **64** tracked files changed (32 server geo endpoints, 21 form scripts, 2 leads-site geo endpoints, lockfile + root override, 1 MBS SEO fix, docs) plus 2 new docs. No commit made yet — awaiting your go-ahead. No secrets, `node_modules`, or build output touched.

Generated from branch work/astro-sites • figures verified by local build + runtime curl on 11 Aug 2026.